

Founder Brief: GTM and Outbound Working Document

Triagent: What a potential co-founder needs to run discovery, GTM, and outbound

Alexander Hülsmann – repository-grounded snapshot

Short version

Triagent is a **working self-hosted / on-prem phishing-triage demo stack** for regulated environments and MSSPs. The core story is **evidence-first phishing triage**: reported emails should not be investigated across scattered tools and then documented manually. Instead, analysts should review the message, inspect technical evidence, make a decision, and export a defensible case record in one workflow. A likely wedge is **automation-first triage**: separate **real analyst-worthy phishing** from **spam / graymail / routine benign mail** and identify a lane of **commodity malicious reports that may be safe for automation-first handling**. Today the product is **real enough for discovery, demos, and early pilots**; it is **not yet an enterprise-ready product**. GTM work should therefore optimize for **design-partner discovery**, not for closing broad production deployments.

What Triagent is in one sentence

Triagent is an **evidence-first, analyst-in-the-loop phishing-triage workspace** for SOC / SecOps teams that want faster, more defensible decisions without pushing suspicious mail into external SaaS workflows.

Who it is for

- **Primary user**: SOC analysts, SecOps analysts, phishing-triage teams, and MSSP teams that repeatedly investigate suspicious emails.
- **Champion**: more likely a **CISO, SOC manager, SecOps manager, or MSSP service lead** who owns phishing-triage outcomes, analyst efficiency, and reporting quality; analyst pull still matters, but the internal sponsor is likely to be more senior.
- **Likely buyer**: SOC lead, Head of SecOps, MSSP service lead, or CISO in environments with privacy, data-residency, or on-prem requirements.
- **Best initial ICP**: regulated organizations and MSSPs / **managed security teams** with recurring phishing volume, an existing mailbox or reported-mail workflow, and meaningful documentation pressure.
- **Do not prioritize now**: tiny teams with almost no phishing workflow, generic IT shops, awareness-only buyers, or anyone expecting a complete email-security gateway replacement.

What pain it solves

- Phishing triage is often **tool-fragmented**: mail client, header checks, URL tools, attachment review, analyst notes, ticket or case update, then IOC handoff.
- Security teams often need more than a verdict; they need **evidence, rationale, exportability, and auditability**.
- In regulated environments, **external upload / SaaS-first workflows can be politically or technically difficult**.
- Similar phishing emails are often handled repeatedly instead of being treated as **one campaign or wave**.
- The cost is not just analysis time; it is also the burden of producing a **decision-ready case file**.

Mental model of the workflow

- Ingest reported mail via upload or Outlook add-in.
- Normalize headers, URLs, attachments, message metadata, and original-message provenance.
- Review triage signals, authentication outcomes, lookalike signals, URLs, attachments, transmission path, and raw source.
- Produce an analyst decision with suggested disposition support, flagged artifacts, and rationale.
- Export evidence and IOCs, preserve the original sample, and keep an attributable audit trail.
- In the broader product vision, cluster related reports into campaigns so repeated work collapses into campaign-level handling.

What exists today in the repository

- **Analyst workspace**: Next.js UI with uploads, in-tray, dashboard, admin pages, audit pages, and full report view.
- **Intake**: .eml and .msg ingestion, batch file ingest, and Outlook add-in support.
- **Evidence review**: sender and mailbox metadata, transmission hops, raw source, attachments, original-message preservation, URL extraction and optional redirect resolution.
- **Auth / message analysis**: SPF, DKIM, DMARC, ARC, reply / return-path mismatch signals, and same-org lookalike detection.
- **Triage support**: persisted triage assessment fields, queue prioritization, and local assist drafts that recommend classification and flagged artifacts, while explicitly requiring analyst approval.
- **Automation-first triage lanes**: reports can already be bucketed into **NEEDS_INVESTIGATION**, **AUTOMATION_READY**, **BULK_SPAM**, **LIKELY_BENIGN**, and **UNCERTAIN**. This means the repo already supports the product story of distinguishing **true phishing that deserves analyst time** from **spam / graymail / routine benign traffic**, plus a lane for **commodity malicious handling**.
- **Exports**: report evidence export as JSON / Markdown / PDF and IOC export as JSON / CSV.
- **Governance**: session-based RBAC, API keys, append-only hash-chained audit logging, audit verification, and export workflows.
- **Campaign layer**: campaign schema, assignment, reclustering, reassignment, merge / split / lock flows, campaign reports, events, and campaign evidence exports are implemented in backend APIs and data model.
- **Demo readiness**: Docker Compose deployment, hardening docs, threat model, rollback runbook, and a synthetic phishing corpus with sample investigation scenarios.

What is still directional, partial, or not ready for claims

- The product is a **strong demo / pilot prototype**, not a production-certified enterprise platform.
- Compose-based self-hosting exists; **enterprise packaging, secrets management, and hardened operating model** are still incomplete.

- **Enterprise SSO / IdP** is not complete in the public demo; LDAP hooks exist, but this is not a polished enterprise auth story yet.
- **Deep ticketing / SIEM / SOAR integrations** are not the current truth line.
- **Auto-resolving or auto-closing external tickets / cases** is a plausible future wedge, but it is **not the current implemented truth**. The grounded claim today is **automation-first triage recommendation and queue separation**, not end-to-end autonomous case closure in third-party systems.
- **Mailbox remediation, malware detonation, remote browser isolation, and auto-enforcement** are out of scope for the current demo.
- Campaign handling is real in backend capabilities, but the open product question remains whether the first wedge is **single-report evidence handling or campaign-level workflow**.
- There is **no defensible public ROI claim yet**; time-savings, analyst-load reduction, and automation-rate claims still need customer validation.

How GTM should position it

- Lead with **workflow pain**, not with “AI copilot” language.
- Best framing: **evidence-first phishing triage for regulated environments and MSSPs**.
- **Less swivel-chair work**: fewer scattered checks and less manual case write-up.
- **Defensible decisions**: original message, artifacts, rationale, exports, and audit trail stay together.
- **Privacy / on-prem direction**: suitable for teams that do not want suspicious mail pushed into external SaaS tooling.
- **MSSP angle**: useful where service teams need repeatable handling, consistent case files, and a clearer way to manage customer phishing volume.
- **Campaign upside**: similar reports should not create full repeated work each time.
- **Likely wedge to validate**: use automation-first triage to separate **real phishing that deserves analyst attention** from **spam / graymail / benign routine mail**, and potentially route clear-cut commodity cases toward **automation-first handling**.

How outbound should open

- Best CTA: a **20-minute workflow-discovery call** or a **30-minute synthetic walkthrough**, not a generic product pitch.
- Safe opener: “We are speaking with security teams that still investigate reported phishing mail across multiple tools and then manually assemble the case record. I would like to understand how your workflow works today.”
- Safe follow-up angle: “Is the bigger pain the investigation itself, the evidence / reporting burden, or repeated work from similar mails and campaigns?”

Claims a co-founder may safely make

- Triagent is a **working self-hosted / on-prem demo stack** for phishing triage.
- The current demo supports **reported-mail ingestion, analyst review, evidence export, IOC export, auditability, and analyst-in-the-loop resolution**.
- The product is designed for **regulated or privacy-sensitive environments**.
- The workflow is **evidence-first and analyst-centered**, not blind automation.
- Campaign clustering and campaign evidence flows are **part of the current product direction and implemented in backend scope**, but still need primary product validation.

Claims a co-founder must not make

- “Production-ready”, “fully enterprise-ready”, or “already deployed at scale”.
- “Fully autonomous classification” or “no analyst needed”.
- “Already deeply integrated with ServiceNow / Jira / Splunk / M365” unless the exact demonstrated scope is shown.
- “Proven time savings” or quantified ROI without customer-backed evidence.
- Any statement based on internal employer data, internal customer details, internal screenshots, or non-public operational specifics.

What GTM and outbound should try to learn

- How many suspicious-email cases arrive per week or month?
- Who actually handles them, and how senior is that person?
- Which tools are touched during one investigation?
- How much work is in the **decision** versus the **documentation / closure**?
- How much analyst time is currently wasted on **spam, graymail, and benign-but-reported mail** that never should have reached full investigation?
- Are similar mails handled repeatedly, or already grouped into waves / campaigns?
- Are external uploads or cloud processing restricted?
- Is the bigger pain **single-case evidence handling, campaign-level repetition, or distinguishing true phishing from spam / nuisance mail fast enough to protect analyst time**?
- If the team already has tickets or case queues, which classes of reports would they trust a system to **auto-close, auto-resolve, or de-prioritize**?
- Who owns budget, and what would make a design-partner or pilot worth running?

Recommended motion for the next wave of GTM work

- Optimize outreach for **workflow-discovery calls**, not broad sales.
- Use the synthetic corpus and sample investigations for repeatable demos instead of real customer mail.
- Qualify for: recurring phishing volume, analyst pain, reporting burden, privacy constraints, and willingness to discuss a pilot.
- Try to convert the best conversations into **design-partner candidates** with a narrow pilot scope.
- Keep the core wedge question open and explicit: **what pulls harder first, evidence-first single-report handling, campaign workflow, or automation-first separation of true phishing from spam / benign reported mail**?

Guardrails

- No internal FI / employer specifics.
- No internal data, logos, screenshots, or customer details.
- No promises beyond the demonstrated prototype.
- No language that creates employment-conflict or ownership ambiguity.

What a co-founder candidate should get from the founder

- This brief.
- The existing founder one-pager.
- A 5-slide mini deck.
- 3–5 screenshots or a short Loom based on synthetic or redacted demo data.
- A standard discovery-question sheet and shared CRM / pipeline tracker.

Bottom line

The product already has enough substance for serious customer discovery. The correct GTM posture is **narrow, truthful, and evidence-led**: Triagent is not yet “finished”, but it is concrete enough to test whether regulated SOC teams will pull hardest on **evidence-first phishing case handling, campaign deduplication**, or both together.